Zero Trust Security with OCI

OUT1015 Practice 1: Get the Password Out of the Code

Table of Contents

Zero Trust Security with OCI **1**

Introduction 3

About This Workshop 3

Architecture 3

Get Started 5

Prerequisites 5

Sign In to the Lab Tenancy 5

Sign In and Check Your Region 5

Find Your Participant Number 5

How to Read This Guide 6

Practice 1: Get the Password Out of the Code 7

Introduction 7

Objectives 7

Prerequisites 7

Practice 1-1: Create Your Master Encryption Key 7

Practice 1-2: Store the Password as a Secret 9

Practice 1-3: See How the Instance Is Authorized 11

Practice 1-4: Connect to the Tools VM 12

Practice 1-5: Retrieve the Password at Runtime 13

Practice 1-6 (Optional): Retrieve the Secret with the OCI CLI 14

Checkpoint: What You Proved 14

Learn More 15

Need Help? 16

Clean Up 17

Delete Your Secret and Key 17

Acknowledgements 18

Copyright © 2026, Oracle and/or its affiliates.

Introduction

About This Workshop

Summit Retail is moving its online store to Oracle Cloud Infrastructure (OCI). Asha leads cloud security for the move. Over one day she handles a series of security incidents, and each one leads to a Zero Trust decision: grant access on purpose, verify every request, and assume that one control can fail.

You watch some incidents as instructor demonstrations, and you fix three of them yourself. Each practice starts with what Asha sees, shows you the part of the architecture involved, and then gives you short tasks. After each task you compare your result with the expected result.

This guide covers **Practice 1: Get the Password Out of the Code**. The workshop has four practices, each in its own guide. Do Practice 0 first: it builds the environment that the other practices use. Practices 1, 2, and 3 each need only Practice 0, so you can do them in any order.

Practice	What you do	Time
Practice 0	Prepare your Summit Retail environment (Cloud Shell, Terraform)	20 minutes
Practice 1	Get the password out of the code (OCI Vault, instance principals)	25 minutes
Practice 2	Keep the private application private (Security Lists, NSGs, Bastion)	30 minutes
Practice 3	Inspect the requests, not only the port (Web Application Firewall)	35 minutes

Architecture

Practice 0 builds everything in the diagram except the vault, which the lab team prepared, and the WAF policy, which you add in Practice 3. The badges show where each practice works.

Copyright © 2026, Oracle and/or its affiliates.

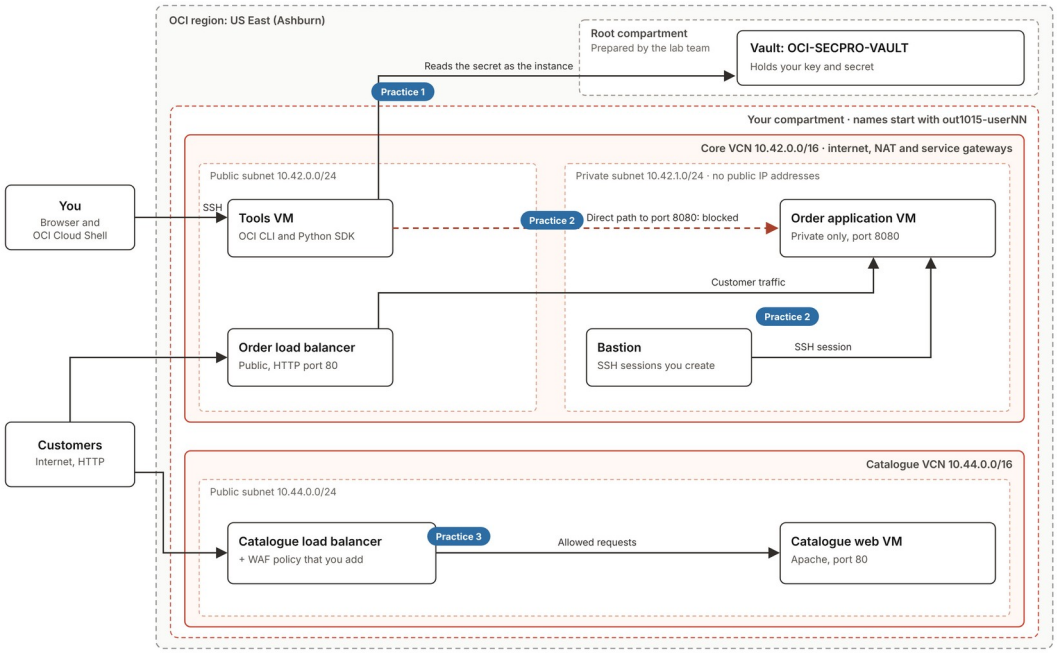


Figure 1: The Summit Retail lab environment in your compartment

The core VCN holds the order system. Customers reach the order application only through the public load balancer. The application server has no public IP address, and you reach it for administration only through OCI Bastion. The Tools VM plays the role of an administrator's or another team's machine inside the same VCN. A second VCN holds the product catalogue, which you protect with WAF.

Copyright © 2026, Oracle and/or its affiliates.

Get Started

Prerequisites

- The lab account details from your instructor: the sign-in URL or tenancy name, your username and password, and your assigned compartment.
- A laptop with a current web browser. You need no other software, because every command runs in OCI Cloud Shell.

Sign In to the Lab Tenancy

Your instructor gives you a lab account in a shared tenancy. Every participant works in their own compartment, so your resources never mix with anyone else's.

Sign In and Check Your Region

1. Open the sign-in URL from your lab details, or go to `https://cloud.oracle.com` and enter the tenancy name.

2. Sign in with the username and password from your lab details. If you are asked to change the password, choose a new one and keep it for the rest of the day.

3. In the Console header, open the region selector and select **US East (Ashburn)**. Every practice uses this region.

4. From the navigation menu, select **Identity & Security**, and then click **Compartments**. Find your assigned compartment in the list, for example `98507690-C07`.

   > **Expected result**
   >
   > You are signed in, the region is US East (Ashburn), and you can see your assigned compartment.

Find Your Participant Number

1. Look at your username. It ends with your participant number, for example `98507690-lab.user07`.

2. Write down the last part, `userNN`, for example `user07`. Everywhere this guide shows `userNN` or `NN`, use your own number.

Copyright © 2026, Oracle and/or its affiliates.

> **Note**
>
> Your compartment uses the same number: user07 works in compartment 98507690-C07. The Practice 0 package reads both from your username, and asks you to confirm them.

How to Read This Guide

You see	It means
A light box with a red left edge	Text that you enter or select in the OCI Console.
A dark box that starts with $	A command to run. The task tells you where: in Cloud Shell or on a VM. Do not type the $.
A gray box	Output that you should see. Details such as IDs, dates, and IP addresses differ for you.
Expected result	What to check before you move on.
`<value>`	A placeholder. Replace it with your own value, without the angle brackets.

> **Note**
>
> Console labels sometimes move between releases. If a button is not where the guide says, look for the same action in the **Actions** menu or under the three-dot icon.

Copyright © 2026, Oracle and/or its affiliates.

Practice 1: Get the Password Out of the Code

Introduction

Summit Retail's order application needs a database password, and today the password sits in the application's configuration file. During a support case, someone attached that file to a ticket, and the password went with it. Every copy of the file is one more place where the password can leak.

Asha's fix: store the password once, as a secret in OCI Vault, encrypted with a key that Summit Retail controls. The application keeps only the secret's Oracle Cloud ID (OCID), which is a reference, not the password. When the application runs on an OCI instance, it proves who it is as that instance, an instance principal, and fetches the password when it needs it. No password and no API key are stored on the server.

Estimated time: 25 minutes.

Objectives

- Create a master encryption key and store a dummy password as a secret in the shared vault.
- Read the policy that lets your instance read secrets, and see how a dynamic group recognizes the instance.
- Run the order application on the Tools VM and watch it retrieve the password with its instance principal.

Prerequisites

- Practice 0 is complete, and you have your `tools_public_ip`.
- The lab team prepared the shared vault `OCI-SECPRO-VAULT`, the dynamic group, and the IAM policy. You use them, but never change them.

Practice 1-1: Create Your Master Encryption Key

1. From the navigation menu, select **Identity & Security** > **Key Management**, and then click **Vault**.

2. Next to **Applied filters**, make sure that the root compartment is selected. From the list of vaults, click **OCI-SECPRO-VAULT**. Check that the region is **US East (Ashburn)**.

Copyright © 2026, Oracle and/or its affiliates.

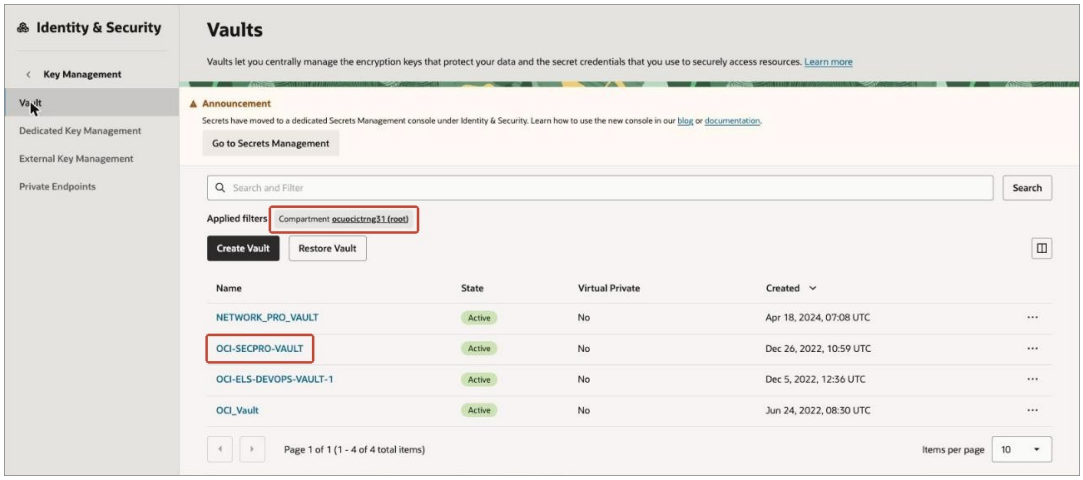


Figure 2: The shared vault is listed under the root compartment

3. Click the **Master encryption keys** tab. Next to **Applied filters**, select your assigned compartment, and click **Create Key**.

4. Enter these values, leave the other fields at their defaults, and click **Create Key**:

Field	Value
Create in compartment	Your assigned compartment
Protection mode	**HSM**
Name	`out1015-userNN-key`
Key shape: Algorithm	**AES**
Key shape: Length	**256 bits**

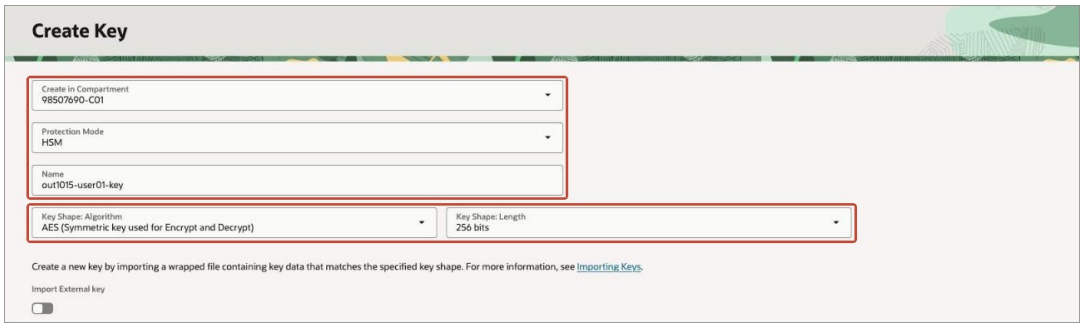


Figure 3: Create Key: your compartment, HSM protection, and an AES 256-bit key

5. Wait about a minute, until the key is no longer in the **Creating** state. The key appears in the list.

Copyright © 2026, Oracle and/or its affiliates.

> **Note**
>
> HSM protection means the key never leaves a hardware security module. The vault is shared, but each participant's keys and secrets live in their own compartment.

Practice 1-2: Store the Password as a Secret

1. From the navigation menu, select **Identity & Security** > **Secret Management**.
2. Next to **Applied filters**, select your assigned compartment and the vault **OCI-SECPRO-VAULT**, and click **Create secret**.
3. Enter these values:

Field	Value
Create in compartment	Your assigned compartment
Name	`out1015-userNN-db-password`
Description	`Summit Retail order database password (dummy)`
Vault compartment	The root compartment
Vault	**OCI-SECPRO-VAULT**
Encryption key compartment	Your assigned compartment
Encryption key	`out1015-userNN-key`
Secret generation	**Manual secret generation**
Secret type template	**Plain-Text**
Secret contents	`SummitDemoOnly-2026!`
Cross-region replication	Leave off

> **Note**
>
> **Vault compartment** starts as your own compartment. Change it to the root compartment first; only then is `OCI-SECPRO-VAULT` listed under **Vault**.

Copyright © 2026, Oracle and/or its affiliates.

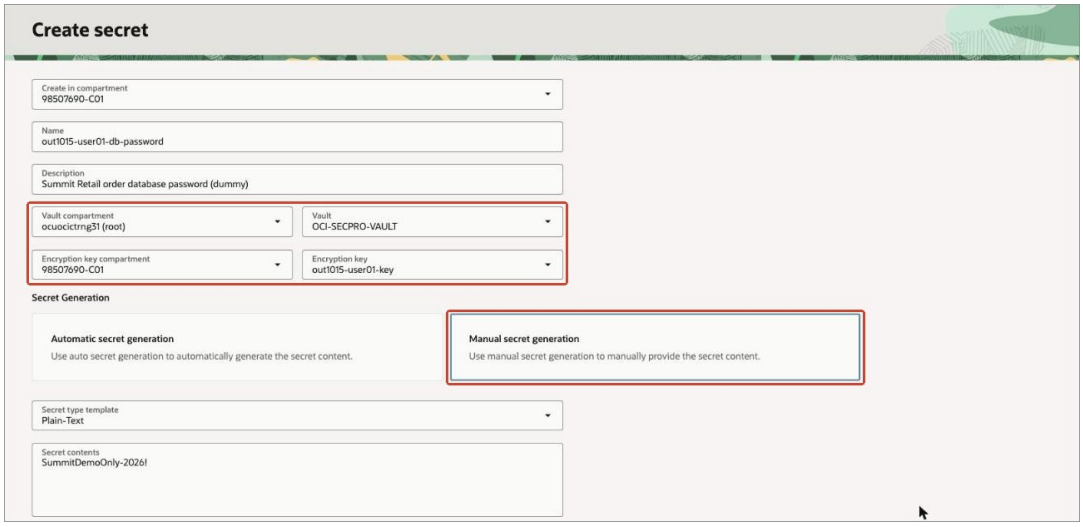


Figure 4: Create secret: the shared vault in the root compartment, your key, and manual secret generation

4. Click **Create secret**, and wait until the secret is **Active**.

5. Click `out1015-userNN-db-password`, and copy its **OCID**. It begins with `ocid1.vaultsecret.`. Paste it into your text file; you need it in Practice 1-5.

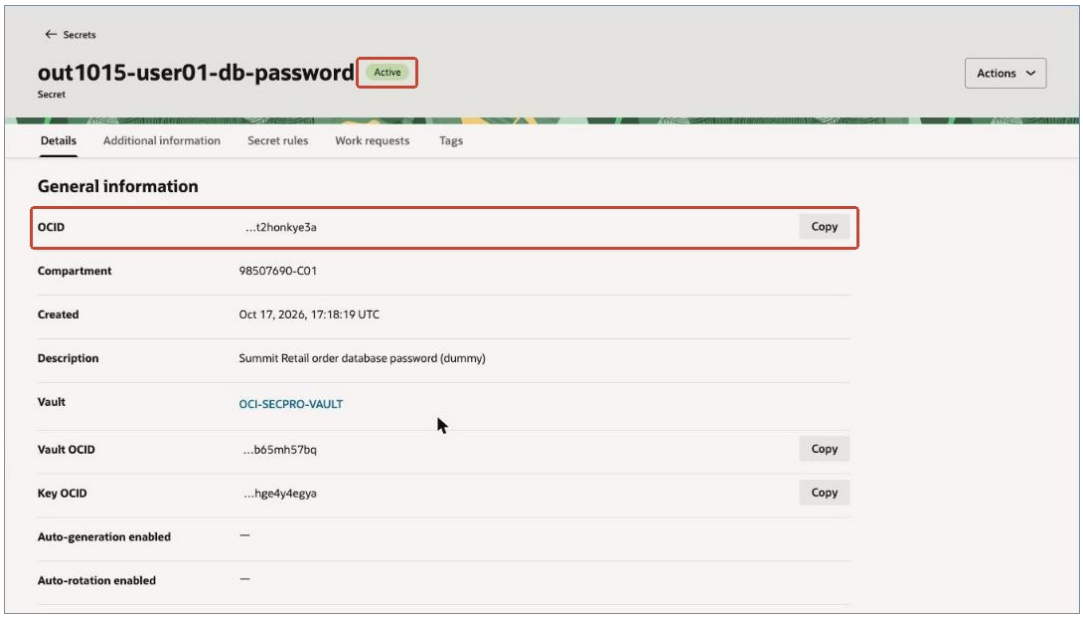


Figure 5: The secret is Active. Copy the OCID at the top of General information

> **Caution**
>
> Use only a dummy value in this practice. Never store a real password here.
>
> Copy the Secret OCID, not the vault or key OCID. The application fails with any other kind of OCID.

Copyright © 2026, Oracle and/or its affiliates.

> **Note**
>
> Secret names must be unique in the vault, and OCI keeps a deleted secret's name reserved for several days. If you see **name already exists**, add `-2` to the name, for example `out1015-user07-db-password-2`.

Practice 1-3: See How the Instance Is Authorized

The application will run without a password and without an API key. OCI gives each instance its own certificate, and the instance signs its requests with it. That identity is the instance principal. Two IAM objects turn it into permission: a dynamic group, whose rule decides which instances belong to it, and a policy that grants the dynamic group access. In this task you only read them.

1. From the navigation menu, select **Identity & Security**, and then click **Policies**. Next to **Applied filters**, select your assigned compartment.

2. Click the policy whose name starts with `POL`, for example `POL98507690-C07`. The lab team created it for your compartment. If an **Introducing IAM Deny** message appears, click **Close**.

3. Click the **Statements** tab. In the search box, enter `SecurityProDynamicGroup`, and click **Search**. Find the two statements about secrets and keys:

```
Allow dynamic-group SecurityProDynamicGroup TO READ secret-family
  IN COMPARTMENT 98507690-CNN
Allow dynamic-group SecurityProDynamicGroup TO USE keys
  in compartment 98507690-CNN
```

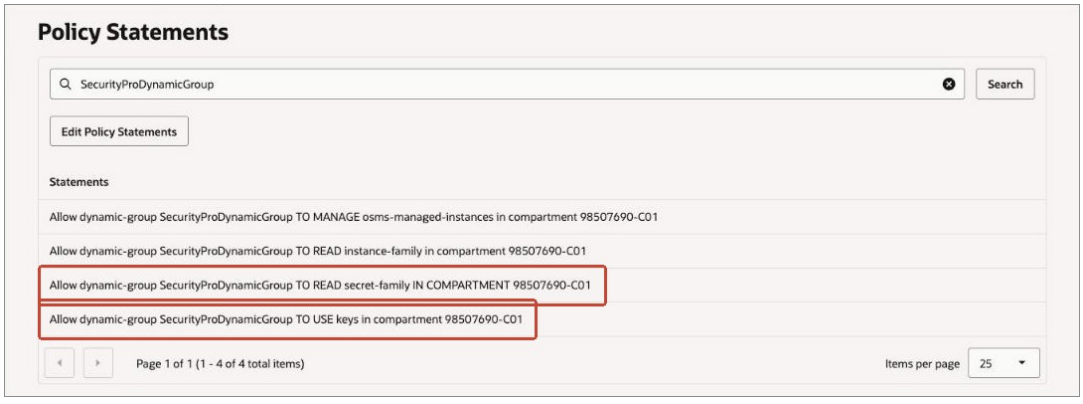


Figure 6: The policy statements that let the dynamic group read secrets and use keys

4. Read the first statement in three parts. **Who:** any instance in the dynamic group `SecurityProDynamicGroup`. **What:** read secrets and their contents. **Where:** your compartment.

Copyright © 2026, Oracle and/or its affiliates.

5. The lab team wrote the dynamic group's rule by compartment, so every instance in your compartment belongs to it, including your Tools VM. A rule of that kind looks like this:

```
All {instance.compartment.id = '<your-compartment-ocid>'}
```

> **Note**
>
> Knowing a Secret OCID grants nothing by itself. A request succeeds only when the caller's identity is allowed by a policy.
>
> A rule by compartment includes every instance in that compartment. A tighter rule names one instance OCID or a tag, so that only the order application can read the secret.

Practice 1-4: Connect to the Tools VM

The application must run on the instance, because only code running there can use the instance's identity. The Tools VM plays the order application's server in this practice.

1. In Cloud Shell, connect to the Tools VM. Replace `<tools_public_ip>` with your value from Practice 0. When SSH asks whether to continue connecting, type `yes`:

```
$ ssh -i ~/out1015-lab/.local/workshop_ssh opc@<tools_public_ip>
```

```
[opc@summit-test ~]$
```

2. Check that the OCI command line interface (CLI) and the Python software development kit (SDK) are installed:

```
$ oci --version
$ python3.9 -c 'import oci; print(oci.__version__)'
```

```
3.x.x
2.x.x
```

> **Note**
>
> From here until the end of Practice 1-6, every command runs on the Tools VM, at the `[opc@summit-test ~]$` prompt. Cloud Shell is only the window you connect from.
>
> If `oci` is not found, the VM is still installing its software. Wait a minute and check again.

Copyright © 2026, Oracle and/or its affiliates.

Practice 1-5: Retrieve the Password at Runtime

1. On the Tools VM, create a folder and download Oracle's sample application. The address points to a fixed version of the script:

```
$ mkdir -p ~/lab1 && cd ~/lab1
$ SRC=https://raw.githubusercontent.com/ou-developers
$ REV=oci-vaultoperations/f0aac574e5e23e7fd656d7470352d50fd7346870
$ wget -q -O getsecret.py $SRC/$REV/getsecret.py
```

2. Store your Secret OCID in a variable. Replace `<secret-ocid>` with the OCID from Practice 1-2, and keep the single quotes:

```
$ SECRET_OCID='<secret-ocid>'
```

3. Put the OCID into the script, and check the result. The `secret_id` line must show your OCID:

```
$ sed -i "s|ocid1.vaultsecret.oc1.<my_secret_ocid>|$SECRET_OCID|" \
  getsecret.py
$ grep '^secret_id' getsecret.py
```

```
secret_id = "ocid1.vaultsecret.oc1.iad.<your-secret-id>"
```

4. Read the script, and find these lines:

```
$ cat getsecret.py
```

Line in the script	What it does
`secret_id = ...`	Stores the reference to the secret. It is the only secret-related value in the code.
`InstancePrincipalsSecurityTokenSigner()`	Signs requests with the instance's own identity. No password or API key is involved.
`get_secret_bundle(secret_id)`	Retrieves the current version of the secret.
`base64.b64decode(...)`	Decodes the contents. The service returns them Base64-encoded, which is an encoding, not encryption.

5. Run the order application:

```
$ python3.9 getsecret.py
```

```
SummitDemoOnly-2026!
```

Copyright © 2026, Oracle and/or its affiliates.

> **Expected result**
>
> The script prints the dummy password that you stored in Practice 1-2, although the password appears nowhere in the script or on the VM.

Practice 1-6 (Optional): Retrieve the Secret with the OCI CLI

1. Retrieve the same secret with the CLI, also as the instance. `--auth instance_principal` tells the CLI to use the instance's identity; the VM has no configuration file or API key:

```
$ oci secrets secret-bundle get --secret-id "$SECRET_OCID" \
  --stage CURRENT --auth instance_principal --region us-ashburn-1 \
  --query 'data."secret-bundle-content".content' --raw-output \
  | base64 --decode; echo
```

```
SummitDemoOnly-2026!
```

2. Leave the Tools VM:

```
$ exit
```

Checkpoint: What You Proved

The password left the code. The application holds only a reference, and IAM decides at the moment of use whether the instance may read the secret. Answer these questions, then compare your answers:

- Another team receives only your Secret OCID. Can they read the password?
- Another instance is created in your compartment. Can it read your secret?
- An attacker gets a shell on your Tools VM. What can they do with the secret?
- The database password must change. What changes in the application?

Copyright © 2026, Oracle and/or its affiliates.

> **Checkpoint**
>
> **1.** No. The OCID is only a reference. The caller still needs an identity that a policy allows to read the secret.
>
> **2.** Yes, with a rule by compartment: the new instance matches the same rule. Scope the rule more tightly when only one workload needs the secret.
>
> **3.** Code on an authorized instance can use the instance's permissions, so the attacker can read the secret too. Protect access to the host, and give each workload only the secrets it needs.
>
> **4.** Nothing in the code. You add a new secret version, and the application receives it on its next retrieval. The database itself must also change to the new password.

Learn More

- OCI Vault overview: https://docs.oracle.com/en-us/iaas/Content/KeyManagement/home.htm
- Calling services from an instance (instance principals): https://docs.oracle.com/en-us/iaas/Content/Identity/Tasks/callingservicesfrominstances.htm

Copyright © 2026, Oracle and/or its affiliates.

Need Help?

Raise your hand, and an instructor will come to you. Before that, check the common problems below.

- `OCI-SECPRO-VAULT` is not listed: select the root compartment next to **Applied filters**, and check that the region is US East (Ashburn).
- You cannot create the key or secret: check that **Create in compartment** is your assigned compartment, not the root compartment.
- **name already exists** when you create the secret: add `-2` to the name.
- SSH reports `Permission denied (publickey)`: use the key from Practice 0, `~/out1015-lab/.local/workshop_ssh`, and the user `opc`.
- The script still shows `<my_secret_ocid>`: set `SECRET_OCID` again with single quotes, and repeat the `sed` command.
- `NotAuthorizedOrNotFound`: check that you copied the Secret OCID, that the secret is Active, and that the region is US East (Ashburn).

Copyright © 2026, Oracle and/or its affiliates.

Clean Up

Clean up when your instructor tells you to, normally at the end of the day. The lab resources incur charges while they exist.

Delete Your Secret and Key

1. From the navigation menu, select **Identity & Security** > **Secret Management**. Next to **Applied filters**, select your assigned compartment and **OCI-SECPRO-VAULT**.
2. Click `out1015-userNN-db-password`, and then click **Actions** > **Delete Secret**.
3. Select the confirmation box, type the secret name, keep or choose the earliest deletion date, and click **Delete Secret**.
4. From the navigation menu, select **Identity & Security** > **Key Management**, click **Vault**, and then click **OCI-SECPRO-VAULT**. On the **Master encryption keys** tab, select your assigned compartment next to **Applied filters**.
5. Click `out1015-userNN-key`, and then click **Actions** > **Delete Key**.
6. Select the confirmation box, type the key name, keep or choose the earliest deletion date (at least 7 days ahead), and click **Delete Key**.

> **Note**
>
> OCI deletes keys and secrets only after a waiting period, which protects against mistakes. Their state shows **Pending Deletion** until then.

Copyright © 2026, Oracle and/or its affiliates.

Acknowledgements

- **Author:** Saurabh Patil, Principal OCI Instructor, Oracle University
- **Workshop:** OUT1015 Zero Trust Security with OCI, Oracle AI World 2026
- **Last updated:** October 2026

Copyright © 2026, Oracle and/or its affiliates.